

Pentesting

Larrain Gonzalez
Gaizka Divasson
Surya Ortega
Asier Barrio
Erlantz Lorz

Sarrera.....	3
Ahulezien Informea.....	4
Arrisku Handiko Ahuleziak.....	4
Arrisku Ertaineko Ahuleziak.....	5
Arrisku Baxuko Ahuleziak.....	7
Alerta Informatiboak.....	11

Sarrera

Txosten honen helburua Informazio Sistemen Segurtasuna Kudeatzeko Sistemak ikasgaiaren lehen lanaren esparruan garatutako web aplikazioari buruz egindako segurtasun-auditoretzan lortutako emaitzak dokumentazioa da.

Ebaluazioa ahultasunak aztertzekeo tresna bat erabiliz egin zen (kasu honetan, OWASP ZAP), erreferentzia gisa OWASP Top 10 estandarra (2021eko bertsioa) erabiliz, zeinak web-aplikazioetako segurtasun-arrisku nagusiak sailkatzen baititu.

Azterketa honen helburua sistemaren konfidentzialtasuna, osotasuna edo erabilgarritasuna arriskuan jar dezaketen ahultasunak identifikatzea da, bai eta arintzeko neurri egokiak proposatzea ere.

Lortutako emaitzak kalteberatasun-motaren arabera antolatuta aurkezten dira, kasu bakoitzean dagokion OWASP kategoria, deskribapena, eragin potentziala, arrisku-maila eta zuzentzeko gomendioak adierazita.

Azkenik, txosten hau oinarri izango da hurrengo lanerako. Bertan, beharrezko zuzenketak ezarriko dira, eta aplikazioa berriro ebaluatuko da, detektatutako arriskuak benetan arintzen direla egiaztatzekeo.

Ahulezien Informea

Arrisku Handiko Ahuleziak

Zenbakia	1
Detektatutako ahulezia	Mysql/Sql injekzioa
OWASP 2021 kodea	A03:2021
Deskribapena	Formularioen parametroen bidez SQL kodea injeztatzeke aukera detektatu da. Sistemak ez ditu kontsulta parametrizatuak erabiltzen, eta erabiltzailearen sarrera-balioak zuzenean sartzen ditu kontsultan, hauek sanitizatu gabe.
Inpaktua/Arrisku maila	Altua. Erasotzaile batek datu-basean datuak sartu, aldatu edo ezabatu ditzake.
Erabilitako atakea	'OR' 1 '=' 1 jarritz formulario batzuetan hurrengoa lortu daiteke: - Baliozko kredentzialik gabe saioa hasi. - Gurea ez den erabiltzaile baten datuak kontsultatu edo aldatu. - Datu baseko babarrun guztien informazioa borratu input bakar batekin.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id} - localhost:81/delete_item?id={id} - localhost:81/show_user?id={id}

Arrisku Ertaineko Ahuleziak

Zenbakia	2
Detektatutako ahulezia	CSFR aurkako token falta
OWASP 2021 kodea	A01:2021 CWE-352
Deskribapena	HTML bidalketa formularioan CSRF aurkako token-ak ez ziren aurkitu. Token-a ez edukitzea ahalbidetzen du HTTP bidalketa bat egitea, biktima bidaltzen duena jakin gabe, erasotzaileak biktima balitz bezala akzio batzuk egiteko, alegia web batera sartzean posible izan liteke formulario bat bidaltzea erabiltzailea jakin gabe eta hori erabiliz erabiltzailearen saiora konektatu daiteke erasotzailea.
Inpaktua/Arrisku maila	Altua: Erasotzaileak biktimaren tokian jarrita, azken honen saioa erabil dezake ez desiratutako akzioak aurrera eramateko, erosketak egin, pasahitza aladtu, besteak beste. Web kudeatzailea izatekotan, konfidantza erabiltzaileengan gal daiteke, ospe txarra lortuz edo banku batean arazo legalak egon ahalko ziren, informazio sentikorra maneiatzen baita.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}

Zenbakia	3
Detektatutako ahulezia	Content Security Policy (CSP) goiburua ez konfiguratuta.
OWASP 2021 kodea	A05:2021 CWE-693
Deskribapena	CSP-k HTTP goiburu baten bitartez, ahalbidetzen dio nabigatzaileari jakitea ze eduki (script, irudiak...) karga eta ejekuta dezake webgunean. CSP ez edukitzeak ez dio nabigatzaileari ahalbidetzen erabiliko diren baliabideak (script, irudiak) kontrolatzea, eta honek eragin dezake hainbat eraso jasotzea.
Inpaktua/Arrisku maila	Altua: Aipatutako erasoak webgunean eman daitezke, erabiltzaileen informazio lapurketatik malware banaketaraino joan daiteke. Hirugarren baten script-aren menpe badago webgunea, edozein script irekiko du, nahiz eta hartutakoa oso fidagarria ez bada.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/delete_item - localhost:81/items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}

Zenbakia	4
Detektatutako ahulezia	Clickjacking aurkako goiburu falta
OWASP 2021 kodea	A05:2021 CWE-1021
Deskribapena	Egindako eskaeraren erantzunak ez du ClickJacking-en aurka babesten. Sistemak ez ditu beharrezko goiburuak konfiguratuta eta honek erasotzaileek ahalbidetzen die Clickjacking eraso bat burutzea.
Inpaktua/Arrisku maila	Altua: Erabiltzaileak baimendu gabeko operazioak egin daitezke, jakin gabe, hala nola, datu ezabaketa, erosketak... Beste eraso batzuk areagotzea, adibidez, CSFR edo XSS. Arazo legalak sor ditzake, baldin eta informazio sentikorra maneiatzen bada edo markaren irudia kaltetu dezake, sare sozialetan “like” ematera derrigortzea.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/delete_item

	- localhost:81/items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}
--	--



Arrisku Baxuko Ahuleziak

Zenbakia	5
Detektatutako ahulezia	HttpOnly flag gabeko Cookie-a
OWASP 2021 kodea	A05: 2021
Deskribapena	Saioko cookieak ez du HttpOnly atributua, eta, beraz, JavaScriptetik eskura daiteke bezeroan. XSS urrakortasun bat edo script maltzur bat izanez gero, erasotzaileak cookiea irakurri edo zabaldu ahal izango luke, eta erabiltzailearen saioa bahitu.
Inpaktua/Arrisku maila	Ertaina: Hirugarreneneko osagaien eragina areagotu daiteke, widgets edo iragarkia zaurgarritasunak badute, Cookie horiek irakur dezake sistemak. Token-ak API key-ak edo bestelako informazio sentikorra script maltxurren eskura geratu daitezke.
Kaltetutako URL-ak	Guztiak

Zenbakia	6
Detektatutako ahulezia	Same site flag gabeko Cookie-a
OWASP 2021 kodea	A01:2021
Deskribapena	Cookie-ak ez du zehazten SameSite atributua, eta horri esker nabigatzaileak cross-site eskaeretan bidal dezake. Hori eskaeren faltsifikazio-erasoetan (CSRF) balia daiteke, eta erasotzaile batek ekintzak egin ditzake autentifikatutako erabiltzaile baten izenean, edo pribilegiadun erabiltzaile baten izenean.
Inpaktua/Arrisku maila	Ertaina: Legitimoak diren integrazioetan (widgets, irfame...) flag honek aktibatuta ez badago kanpoko jatorrietara bidal ditzake Cookie-ak ihesak errazten.

Kaltetutako URL-ak	Guztiak
--------------------	---------

Zenbakia	7
Detektatutako ahulezia	Depurazio errore mezua
OWASP 2021 kodea	A01:2021
Deskribapena	Erantzunak ASP.NET bezalako plataformek eta IIS eta Apache bezalako web-zerbitzariak itzultzen dituzten errore-mezu arruntak izan zitezkeela dirudi. Debug mezu arrunten zerrenda konfiguratu dezakezu.
Inpaktua/Arrisku maila	Ertaina: Erabiltzailearen datuak erakutsi daitezke edo sistemaren barne egitura ikus daiteke, fitxategiak, API-ak, besteak beste.
Kaltetutako URL-ak	- http://localhost:81/sitemap.xml

Zenbakia	8
Detektatutako ahulezia	Aplikazio dibulgazio errorea
OWASP 2021 kodea	A05:2021 - Security Misconfiguration
Deskribapena	Orrialde honek errore/abisu-mezua bat dauka, eta horrek informazio sentikorra ager dezake —adibidez tratatu gabeko salbuespena eragin duen fitxategiaren kokapena. Informazio hori web-aplikazioaren aurkako eraso gehiago abian jartzeko erabil daiteke. Alerta positibo faltsu bat izan daiteke errore-mezua dokumentazio-orrialde baten barruan aurkitzen bada.
Inpaktua/Arrisku maila	Ertaina: Erabiltzailearen datuak erakutsi daitezke edo sistemaren barne egitura ikus daiteke, fitxategiak, API-ak, besteak beste.
Kaltetutako URL-ak	- http://localhost:81/sitemap.xml

Zenbakia	9
Detektatutako	Zerbitzaria informazioa bidaltzen du HTTP erantzun

ahulezia	goiburuaren "X-Powered-By" zatia erabilia.
OWASP 2021 kodea	A05: 2021
Deskribapena	Web zerbitzariak/aplikazioak informazioa dibulгатzen du "X-Powered-By" HTTP erantzun-goiburu baten edo gehiagoren bidez. Informazio hori eskuragarri egoteak erasotzaileei erraztu diezaieke zure web aplikazioa oinarritzen den beste marko/osagai batzuk identifikatzea, eta osagai horiek jasan ditzaketen ahultasunak ezagutzea.
Inpaktua/Arrisku maila	Ertaina: Erasotzaileak informazio baliagarria eskura dezake, teknologia jakinbatek erabilia sistemak dauzkan ahultasunak bilatu ditzake, gero erasoak egiteko.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/delete_item - localhost:81/items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}

Zenbakia	10
Detektatutako ahulezia	Zerbitzarian bertsio informazioa filtratzen du HTTP erantzun goiburuaren "Server" zatia erabilia
OWASP 2021 kodea	A05: 2021
Deskribapena	Web zerbitzariak/aplikazioak bertsio-informazioa filtratzen du "Server" HTTP erantzun-goiburukoaren bidez. Informazio hori eskuragarri egoteak erasotzaileei erraztu diezaieke zure web zerbitzaria/aplikazioa jasan ditzakeen beste ahultasun batzuk identifikatzea.
Inpaktua/Arrisku maila	Ertaina: Informazio baliagarria eman ahal dio erasotzaileari eta informazio hori erabil dezake edozer gauzetarako.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/delete_item - localhost:81/items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}

Zenbakia	11
Detektatutako ahulezia	X-Content-Type-Options goiburua falta da.
OWASP 2021 kodea	A05: 2021
Deskribapena	X-Content-Type-Options MIME-Sniffing-aren aurkako goiburukoa ez zen 'nosniff' gisa ezarri. Horrek ahalbidetzen die Internet Explorer eta Chrome-ren bertsio zaharrei erantzunaren gorputzean MIME-sniffing-a egitea, eta, potentzialki, erantzunaren gorputza deklaraturako eduki-mota ez den beste eduki-mota gisa interpretatu eta bistaratzea eraginez. Firefox-en egungo (2014 hasiera) eta antzinako bertsioek deklaraturako eduki-mota erabiliko dute (bat ezarrita badago), MIME-sniffing-a egin beharrean.
Inpaktua/Arrisku maila	Baxua: Fitxategi faltsuak exekutatu daitezke, adibidez, .png argazki batek HTML eduki bat badu, script gisa interpreta dezake. Eduki-mota okerrak detektatu ditzake, jarritako segurtasun iragazkiak sahistuz, content-type zehatzak erabiltzen dituzte proxyek adibidez, eta hau ez badu bat egiten arazoak sor ditzake.
Kaltetutako URL-ak	- localhost:81/login - localhost:81/register - localhost:81/add_items - localhost:81/delete_item - localhost:81/items - localhost:81/modify_item?id={id} - localhost:81/show_item?id={id}

Alerta Informatiboak

Zenbakia	12
Detektatutako ahulezia	Web aplikazio modernoa
OWASP 2021 kodea	A06:2021
Deskribapena	Aplikazioa web aplikazio modernoa dela dirudi.
Arrisku maila	Informatiboa. Ahulezi bat ez denez, ez dago ezer zuzentzeko.
Kaltetutako URL-ak	localhost:81/login

Zenbakia	13
Detektatutako ahulezia	Erabiltzaileak kontrola dezakeen HTML elementuaren atributua (XSS potentziala)
OWASP 2021 kodea	A03:2021
Deskribapena	Egiaztapen honek erabiltzaileak kontsulta-katearen parametroetan emandako informazioa eta POST datuak aztertzen ditu, HTML atributuen balio jakin batzuk non kontrola daitezkeen identifikatzeko. Horrek XSSrako puntu kritikoen detekzioa ematen du.
Arrisku maila	Informatiboa. Ahulezi bat ez denez, ez dago ezer zuzentzeko.
Kaltetutako URL-ak	localhost:81/

Zenbakia	14
Detektatutako ahulezia	Saio-kudeaketaren erantzuna identifikatuta
OWASP 2021 kodea	A07:2021
Deskribapena	Emandako erantzunak saio-kudeaketa token bat duela identifikatu da.
Arrisku maila	Informatiboa. Ahulezi bat ez denez, ez dago ezer zuzentzeko.

Kaltetutako URL-ak	- localhost:81/modify_user - localhost:81/show_user - localhost:81/show_item - localhost:81/modify_item
--------------------	---